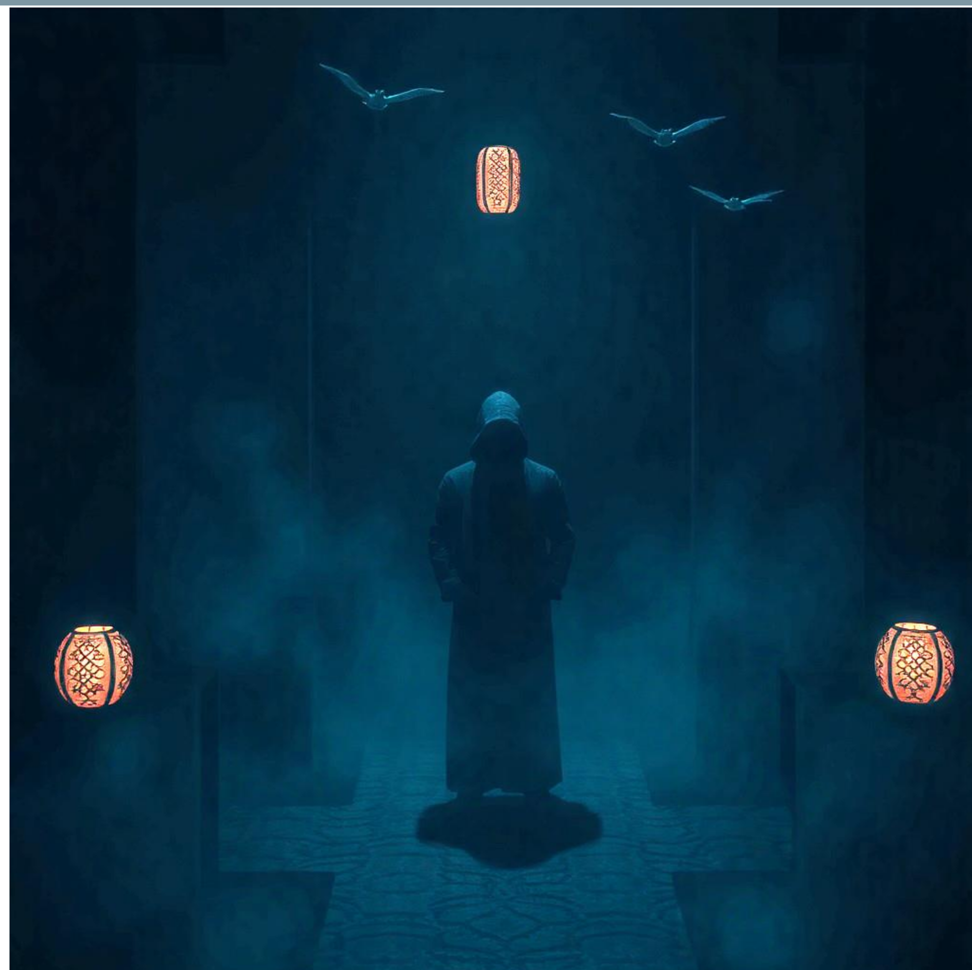
Anti-forensics



Anti-forensics – definition & examples

- **methods, tools, and techniques used to thwart or complicate digital forensic investigations**
- **aim to make it difficult or impossible for investigators to retrieve, analyze, or attribute data that could be used as evidence**
  - code obfuscation (better if dynamic)
  - secure file deletion
  - traffic anonimization
  - transaction untraceability (i.e. thanks to cryptocurrency)
  - tamper-resistant devices and encryption (to hinder forensics access)
  - ...

A possible anti-forensics taxonomy

- **Data Hiding**
  - conceal information or evidence from forensic analysis
- **Artifact Destruction**
  - permanently deleting or corrupting digital evidence
- **Artifact Manipulation**
  - traces alteration to mislead investigators/falsify evidence
- **Obfuscation**
  - transformation of code or data to make analysis and interpretation difficult
- **Network Anti-Forensics**
  - hide or anonymize network activities and communications
- **Memory & Live-System Evasion**
  - evade detection in live analysis/running systems/memory

Data Hiding

- **steganography**
  - hiding data inside another file or medium
  - e.g. *steghide embed -cf image.jpg -ef secret.txt*
- **hidden partitions**
  - concealed disk areas invisible to normal system tools
  - e.g. *parted /dev/sdb set 1 hidden on*
- **encrypted containers**
  - encrypted (and password-protected) storage masking file contents
  - e.g. *veracrypt --create secret.hc*
- **covert channels**
  - hidden communication paths bypassing normal monitoring

Artifact Destruction

- **Secure deletion**
  - forensic sound overwriting data to prevent recovery
  - e.g. *shred -u -n 3 file.txt*
- **Log wiping**
  - removing system or application logs
  - e.g. *Clear-EventLog -LogName Security*
- **Memory cleansing**
  - erasing volatile memory traces
  - e.g. *sdmem –f* (secure memory wiper in Linux secure-delete)
- **SSD TRIM abuse**
  - exploiting SSD deletion mechanisms to hinder recovery.
  - e.g. *fstrim –a* (trim all mounted filesystem)

Artifact Manipulation

- **Timestomping**
  - modifying file timestamps to alter timelines
  - nice "relative" is clock synchronization tampering
  - e.g. *touch -t 202401011200 file.txt*
- **Metadata forgery**
  - changing metadata to falsify evidence context (e.g. *exiftool*)
- **Fake logs**
  - creating counterfeit system or network logs
  - e.g. *logger "System successfully updated"*
- **Log flooding**
  - generating huge amounts of fake log entries to bury real events
  - e.g. filloding with *Jmeter*
- **False-flag artifacts**
  - planting misleading traces implicating others
  - e.g. *set UserAgent "FakeCountryBrowser"*

Obfuscation

- **Packers**
  - compressing/encrypting executables to hide code
  - e.g. *upx malware.exe*
- **Polymorphic/Metamorphic malware**
  - malware that changes appearance across executions
- **Code virtualization**
  - translating code into harder-to-analyze virtual instructions
- **Encrypted payloads**
  - encrypting malicious code until execution time

Network Anti-Forensics

- **MAC spoofing**
  - Faking hardware network addresses.
- **Traffic padding**
  - Adding fake traffic to confuse analysis.
- **Proxy chaining**
  - Routing traffic through multiple intermediaries
- **VPN/Tor**
  - Hiding user identity and network origin

Memory & Live-System Evasion

- **API interception**
  - e.g. rootkits may intercept normal system APIs (and provide modified answers)
- **DKOM (Direct Kernel Object Manipulation)**
  - manipulating kernel structures to hide processes or objects (drivers, network connections, …)
- **Process hollowing**
  - replacing legitimate process memory with malicious code
- **Anti-debugging**
  - detecting and resisting forensic or debugging tools

Anti-forensics – goals & tools

- **data protection and concealment**
  - prevent forensic investigators from accessing sensitive or incriminating data
  - e.g. encryption, steganography, data wiping
- **evasion and misattribution**
  - hide traces of activity to evade detection or divert suspicion to another entity
  - e.g. timestamp and metadata alteration (timestomping), log file counterfeiting, False flag traces, deep fakes

Anti-forensics – goals & tools (II)

- **disruption of forensic processes**
  - corrupt, delete, or tamper with evidence to make it unreliable or inadmissible in legal proceedings
  - e.g. code obfuscation, compression, infection (rootkits & system alteration)
- **privacy preservation**
  - avoid access to personal or corporate private information
  - e.g. proxies, VPN, Tor

Dual nature of anti-forensics

- **By itself not a product of "bad guys"**
  - encryption for privacy
    - hiding criminal evidence
  - Tor for censorship resistance
    - anonymous cyberattacks
  - secure deletion for GDPR
    - destruction of evidence
  - …
    - …
  - …
    - ...

Anti anti-forensics

- **methods, tools, and techniques used by investigators to detect, analyze, prevent, or counter anti-forensic activities aimed at hiding, altering, or destroying digital evidence**
  - file integrity monitoring
  - timeline reconstruction
  - deleted file recovery
  - memory forensics
  - anomaly detection
  - log correlation
  - steganalysis

Anti anti-forensics

- **File Integrity Monitoring (FIM)**
  - detect unauthorized changes to files, logs, or system artifacts by continuously verifying their integrity
  - compute cryptographic hashes (e.g., SHA-256) of critical files
  - store baseline hashes securely
  - periodically or continuously compare current vs baseline state
  - trigger alerts on mismatches
  - e.g *Tripwire*
    - "baseline" of system files and configurations.
    - periodic scan of the system to compare current vs baseline

Anti anti-forensics

- **Forensic Timeline Reconstruction**
  - Process of rebuilding a chronological sequence of system and user events to detect inconsistencies or tampering
  - collect metadata (MAC times, logs, registry, filesystem events)
  - normalize timestamps across sources
  - correlate events into a unified timeline
  - detect gaps, overlaps, or inconsistencies
  - e.g. *Autopsy, sleuth kit, Plaso*

Anti anti-forensics

- **Deleted data recovery (Data Carving)**
  - Technique used to recover deleted or partially overwritten data from storage media
  - scan raw disk sectors for file signatures
  - reconstruct files without filesystem metadata
  - analyze slack space and unallocated clusters
  - e.g. *...you already know*

Anti anti-forensics

- **Memory Forensics**
  - Analysis of volatile system memory to detect hidden processes, injected code, rootkits, ...
  - capture RAM snapshot
  - inspect process lists, DLLs, kernel structures
  - detect anomalies (hidden processes, DKOM manipulation)
  - e.g. *Volatility, Rekall*

Anti anti-forensics

- **Log Correlation and Cross-Validation**
  - compares logs from multiple independent sources to detect inconsistencies or fabricated entries
  - collect logs from OS, network, application, SIEM
  - normalize formats and timestamps
  - cross-check event consistency across systems
  - identify missing or forged entries
  - e.g. *Splunk, Elastic Search*

Anti anti-forensics

- **Steganalysis**
  - Detection and extraction of hidden data embedded within digital media
  - statistical analysis of pixel/audio distributions
  - detection of anomalies in entropy
  - comparison with original or expected distributions
  - machine learning classification of stego content
  - e.g. *steghide, StegExpose, Stegdetect, zsteg*

Anti anti-forensics

- **Secure Logging / Immutable Logging**
  - Technique ensuring logs cannot be altered or deleted without detection
  - Append-only log structures
  - Cryptographic hashing chains (hash chaining)
  - Remote log forwarding to secure server
  - Write-once storage (WORM)
  - e.g. *Syslog-ng, AWS CloudTrail, Splunk*

Anti anti-forensics

- **Behavioral Forensics**
  - Detection of deviations from normal system or user behavior patterns to identify hidden or manipulated activity
  - build baseline of normal behavior
  - apply statistical or ML models
  - detect outliers in system calls, network traffic, or user actions
  - e.g. *ELK Stack, Splunk UBA, Zeek*